安全 RAG 助手改进进度报告

姓名：房楷涵 学号：2024012348 日期：2026-10-25

1. 架构与思路设计（本人设计）

输入校验 → 公共库检索 → 材料整理 → 提示词构建 → 模型生成 → 输出校验。

保留课程接口，将防护放在输入、检索材料、提示词和输出四个环节。检索侧选择少量相关资料并限制上下文长度，引用与实际使用的材料保持一致；提示词侧区分应用规则和外部数据，减少资料中的指令对任务的干扰。

正常知识问题在资料不足时说明依据并尽力回答；要求越权、泄露或绕过检查的请求予以拒绝，避免把知识不足当作安全拒答。

代码实现与自动化测试使用 AI 辅助完成。

2. 本次代码改进

改进项	实现内容
输入与输出防护	规范化输入，增加组合风险规则；检查 JSON、拒答字段及引用范围，拦截敏感输出。
提示词隔离	对问题、资料和来源标签转义；完整检查固定模板，防止伪造边界。
检索与引用	清洗污染段落、去重和轻量重排；统一字符预算，按实际材料生成引用。
接口与配置	校验参数，隐藏 Token 并脱敏错误；内网请求默认绕过环境代理。

3. 验证结果

10 月 18 日已跑通上传、检索和对话等 9 项真实接口验证，并完成 803 条公开集评估。此次从新代码包解压复核，14 项离线测试全部通过；输入护栏拦截 177 条攻击，626 条正常题均放行。

指标	在线实测结果
公开集总正确率	90.16%（724 / 803）
正常知识题正确率	87.38%（547 / 626）
攻击拒答率	100.00%（177 / 177）
正常题误拒 / 接口错误	0 / 0

表中在线成绩沿用 10 月 18 日记录，本周未重跑在线全量评估。公开集参与了开发，隐藏集效果和引用的语义支持度尚未验证。

4. 运行与后续工作

使用 Python 3.10+，安装依赖并在本地配置 Token 后运行 main.py，具体命令见代码包 README。下一步复核 79 条错题，改善检索相关性与简答题覆盖，并检查引用是否支持答案。